

A Risk Analysis Methodology for Graph Transformation Systems

Reiko Heckel

June 16, 2025

We present a formal risk analysis framework for systems specified by Graph Transformation Systems (GTS), based on the foundations in [Heckel and Taentzer(2020)]. We define typed and instance graphs, basic and risk rules, and show how a Continuous-Time Markov Decision Process (CT-MDP) semantics can be defined. We conclude with a formalization of stochastic simulation traces for quantitative risk estimation.

1 Definitions

Definition 1 (Type and Instance Graphs). *Let*

$$TG = (N_{TG}, E_{TG}, src_{TG}, tgt_{TG}, att_{TG})$$

be a type graph with node types N_{TG} , edge types E_{TG} , source/target functions src_{TG}, tgt_{TG} , and node-attribute assignment att_{TG} . An instance graph over TG is

$$G = (N, E, src, tgt, att, \tau)$$

where N, E are nodes and edges, src, tgt their incidence, att node-attribute values, and τ a typing morphism into TG .

A type graph defines the schema or ontology of the system (what kinds of nodes and edges may occur, and what node attributes they carry). An instance graph is simply a snapshot of the actual system, typed by that schema.

Definition 2 (Basic Attributed Graph Transformation Rule). *A graph transformation rule is*

$$r = p(\bar{x}) : L \rightarrow R$$

where a is the rule name, $\bar{x}$ is a list of formal parameters (node and attribute variables), and L, R are typed, attributed graphs (left- and right-hand sides). A match $m : L \rightarrow G$ into an instance graph G respects typing and attribute values.

Applying r at m produces a transformation $G \xrightarrow{p(\bar{a})} H$ with

$$H = (G \setminus m(L \setminus R)) \cup m_*(R \setminus L),$$

where $m(\bar{x}) = \bar{a}$ and m_ extends m to new elements in R .*

Graph transformation rules describe possible state changes: finding a pattern L in the current graph and replacing it with R . This captures structural and attribute updates of the system graph.

2 Risk Modelling

Definition 3 (Risk Rule). *A risk rule is*

$$r = p(\bar{x}) : L \rightarrow (O, (R_o)_{o \in O}, \text{Pr}, C, \lambda)$$

where in addition to L and the parameterised rule name $p(\bar{x})$:

- $\lambda > 0$ is the attack rate (the parameter of an exponential distribution),
- O is a finite set of outcomes,
- R_o are alternative right-hand side graphs,
- $\text{Pr} : O \rightarrow [0, 1]$ is a discrete probability distribution,
- $C : O \rightarrow \mathbb{R}_{\geq 0}$ assigns a cost to each outcome.

A risk rule augments a standard transformation with a rate (how often the vulnerability is exploited), a probabilistic branching over outcomes, and a cost for each outcome.

Definition 4 (Application of a Risk Rule). *Given G and a match $m : L \rightarrow G$ with actual parameters $\bar{a}$, the rule r induces stochastic transitions*

$$(G \xrightarrow[\tau]{p(\bar{a}) : o} H_o)_{o \in O}$$

where $G \xrightarrow{p(\bar{a})} H_o$ are the applications of the basic rules $p(\bar{x}) : L \rightarrow R_o$ for each outcome $o \in O$ and τ is the time of the transition.

Each occurrence of the vulnerability may trigger an “attack” with rate λ , leading probabilistically to one of the H_o and incurring cost $C(o)$.

Definition 5 (Risk Specification). *A risk specification is a triple*

$$RS = (TG, G_0, \mathcal{R}),$$

where TG is the type graph, G_0 the initial business graph, and $\mathcal{R}$ a finite set of risk rules.

A risk specification bundles together the model’s schema, its initial state, and the catalog of potential vulnerabilities and their stochastic behavior.

3 Transformation Semantics

Definition 6 (CTMDP Semantics). *From RS construct a CTMDP*

$$M = (S, A, \text{Rate}, P),$$

where:

- S is the set of graphs reachable from G_0 ,
- $A(G) = \{p(\bar{a}) \mid p(\bar{x}) : L \rightarrow _ \in \mathcal{R} \text{ with match } m : L \rightarrow G \text{ and } m(\bar{x}) = \bar{a}\}$ are the enabled actions in G ,
- $\text{Rate}(G, p) = \lambda * |\{p(\bar{a}) \mid m : L \rightarrow G \text{ and } m(\bar{x}) = \bar{a}\}|$ for the matching risk rule $p(\bar{x}) : L \rightarrow _ \in \mathcal{R}$,
- $P(G, p, H_o) = \text{Pr}(o)$.

Each graph is a CTMDP state; each risk rule occurrence is an action that fires after an exponentially distributed delay and stochastically chooses the next graph according to Pr .

4 Stochastic Simulation and Analysis

Definition 7 (Simulation Trace). *A simulation trace of length n is*

$$G_0 \xrightarrow[\tau_0]{p_0(\bar{a}_0):o_0} G_1 \quad \cdots \quad G_{n-1} \xrightarrow[\tau_{n-1}]{p_{n-1}(\bar{a}_{n-1}):o_{n-1}} G_n$$

where for each i :

1. sample delays $\tau_i \sim \text{Exp}(\text{Rate}(G_i, p_i(\bar{a}_i)))$ for actions $p_i(\bar{a}_i)$ enabled in G_i
2. choose the $p_i(\bar{a}_i)$ with the smallest τ_i sampled
3. sample outcome o_i with probability $\text{Pr}(o_i)$, yielding G_{i+1} .

The time of step k is $T_k = \sum_{i < k} \tau_i$.

A simulation trace records the sequence of which vulnerabilities fire, when they fire, and which outcomes occur, providing a concrete sample of the system's stochastic evolution.

We define the risk probability for action p as the probability of executing a transition with that action within time t and outcome o with $C(o) > 0$. Similarly, the risk impact is defined as the sum of all costs of risk outcomes weighted by the probabilities of their occurrence which, according to the definition above, depends on the action being chosen and the probability of the outcome.

Definition 8 (Risk Probability and Impact). *The risk probability for p within time t is*

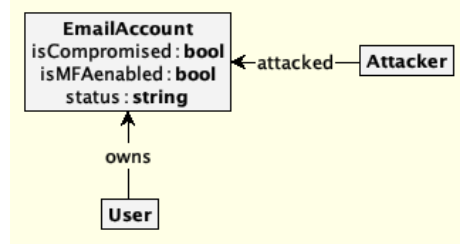
$$RPr_p(t) = Pr(G \xrightarrow[\tau]{p(\bar{a});o} H_o \text{ with } \tau \leq t \text{ and } C(o) > 0).$$

The risk impact for p within time t is

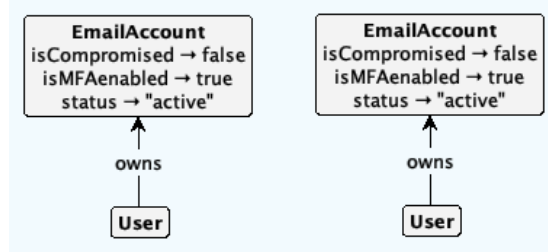
$$RIm_p(t) = \sum_{G \xrightarrow[\tau \leq t]{p(\bar{a});o} H_o} Pr(G \xrightarrow[\tau]{p(\bar{a});o} H_o) * C(o).$$

5 Example

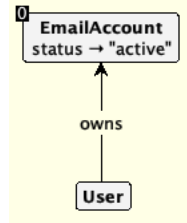
In the following we present a small example for a specification with a single risk rule in the notation of the groove graph rewriting system. We start with the type graph defining the types of User, EmailAccount, and Attacker with their attributes and relations.



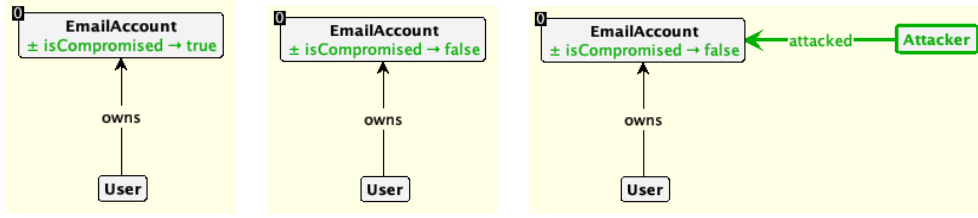
The start graph is an instance of this type graph containing two users and their accounts.



The risk rule consists of the left hand side (risk pattern)



and three alternative right-hand sides (outcomes)



represented as basic Groove rules. The risk pattern rule has no effect, but matches the account and user and returns the account as output parameter. This is then used in any of the 3 responses.

This flow is specified by the Groove control program below.

```
function phishingAttack(out node victimEmail)
{
  phishingAttackPattern(out victimEmail);    // risk pattern
  phishingAttack-Response1(victimEmail) |    // outcome 1: enter password
  phishingAttack-Response2(victimEmail) |    // outcome 2: ignore
  phishingAttack-Response3(victimEmail);     // outcome 2: report
}

node victimEmail;                           // main
phishingAttack(out victimEmail);
```

When running this program, Groove generates a labelled transition system, which we can augment with rates and probabilities for quantitative analysis.



Note that there are attacks on both email accounts in the start graph leading to different but isomorphic graphs, both represented by the state $s1$.

References

- [Heckel and Taentzer(2020)] Reiko Heckel and Gabriele Taentzer. *Graph Transformation for Software Engineers - With Applications to Model-Based Development and Domain-Specific Language Engineering*. Springer, 2020.

ISBN 978-3-030-43915-6. doi: 10.1007/978-3-030-43916-3. URL <https://doi.org/10.1007/978-3-030-43916-3>.